



codewerk

Developing cyber-resilient Railway components for train control and non-safety applications



Connected railway systems on-board trains, at trackside, and at stations can deliver numerous benefits for train operators, staff, and customers. On the other hand, professional and non-professional hackers can pose a serious threat to operational integrity as well as passenger safety – including the perception of safety. Protecting against cyber threats is vital and governments worldwide are developing legislation such as the EU's Cyber Resilience Act (CRA) to protect people, services, and important national infrastructures.

Government legislation draws on existing technical standards to ensure cyber-protection is properly designed and implemented. For connected systems, the IEC 62443 series is expected to be harmonized as the main reference. For equipment providers to demonstrate CRA compliance, product development teams need to be familiar with these and other security-industry standards such as SESIP (Security Evaluation Standard for IoT Platforms).

Choosing appropriate hardware and software as the basis for development can significantly influence the outcome. STMicroelectronics' STM32 general-purpose microcontrollers, and their supporting ecosystem of tools and software, incorporate proven industry-standard security IP that simplifies development, facilitates compliance with cybersecurity legislation, and accelerates time to market.

This whitepaper explains how cyber protection legislation applies to railway systems in both safety-critical and non-safety-critical functions, describes the applicable standards and specifications in detail, and presents resources to help system designers ensure compliance.

CYBER THREATS TO RAILWAY TECHNOLOGY

Railway technology, both on-board trains and at the trackside, is becoming increasingly digitized and interconnected. The aims of system specifiers – including rolling stock manufacturers, service operators and other stakeholders – include ensuring safety, improving operational efficiency, enhancing passenger experiences, and increasing utilization of available infrastructure capacity. On the other hand, digitizing and interconnecting also makes systems more vulnerable to cyber threats from a diverse range of actors with motivations ranging from financial gain to large-scale disruption.

Attacks aimed at critical systems such as speed and braking controls, on-board communication systems, or trackside systems for signaling, switching, and condition monitoring can cause accidents and compromise operational safety. In contrast, attacks on less critical systems such as passenger information systems or heating and lighting can cause discomfort or spread confusion and annoyance, resulting in poor customer experiences.

STANDARDS-BASED PROTECTION

Vendors of systems and components face a growing imperative to ensure robust cybersecurity and need a suitable framework to guide product development and confirm performance against security objectives. Applicable government legislation includes US security directives for rail cybersecurity mitigation, along with the European Union's Network and Information Security (NIS) Directive 2 as well as the Cyber Resilience Act (CRA). The CRA is set to apply from December 11, 2027. Its primary regulatory focus lies on hardware and software products capable of directly or indirectly communicating with other devices or communication networks. This includes railway systems, which typically use data-buses to connect various components to each other and their controllers.

The European Commission has called for European standardization organizations to develop standards that align with the requirements outlined in the CRA. There are

already several widely accepted standards for cybersecurity in digital infrastructure and in the railway sector, including CLC/TS 50701 and the IEC 62443 series of standards. IEC 62443 is among those projected for harmonization to fulfill the CRA in the future. The document "Cyber Resilience Act Requirements Standards Mapping" (ISSN 1831-9424), released by the European Union Agency for Cybersecurity, assesses the correlation between standards such as IEC 62443 and the CRA requirements.

Placing IEC 62443 compliance at the core of development is an effective approach for railway systems design, now and in the future, anticipating that the standard will eventually become fully aligned with the CRA. Aspects that map closely, and those that are not yet aligned, are known. By studying the documentation, developers can work confidently towards certification and testing to prove CRA compliance.

PRODUCT DEVELOPMENT LEVERAGING IEC 62443

The IEC 62443 series is a widely adopted industry standard focused on cybersecurity for industrial automation and control systems (IACS). Developed by the International Electrotechnical Commissions (IEC), this series comprises several documents that address distinct subjects and domains, including:

- General (IEC 62443-1-1 to 62443-1-5)
- Policies and Procedures (62443-2-1 to 62443-2-5)
- System (62443-3-1 to 62443-3-3)
- Component (62443-4-1 to 62443-4-2)
- Evaluation methodology (62443-6-1 to 62443-6-2)

According to this categorization, IEC 62443-4-1 and IEC 62443-4-2 ("Technical security requirements for ICAS components") are the most relevant for component manufacturers. IEC 62443-6-2 may also be of interest as a source of practical examples. Operators and integrators, on the other hand, might focus on other parts of the series and rely on the component manufacturers to comply with part 4-2.

FOUNDATIONAL REQUIREMENTS: IEC 62443-3-3

IEC 62443-3-3 defines seven Foundational Requirements (FRs) which match the ones used in 4-2 but differ in content due to 3-3 targeting system security requirements and 4-2 being dedicated to IACS component security requirements.

1. Identification and authentication control
2. Use control
3. System integrity
4. Data confidentiality
5. Restricted data flow
6. Timely response to events
7. Resource availability

Each FR covers a larger domain and contains several sub-requirements. Additionally, each FR defines the meaning of each security level applied to it.

COMPONENT REQUIREMENTS: IEC 62443-4-2

Component Requirements (CR) are parts of FRs defined in 4-2. The equivalent to CRs from 4-2 in 3-3 are Security Requirements (SR). Each CR specifies a subsection of a FR. The Security Level at which a CR must be implemented is defined on a per-CR-basis.

Specific requirements

In addition to CRs, 4-2 also defines application-specific requirements for some FRs:

List of application-specific requirements

Name	Meaning
SAR	Software Application Requirement
EDR	Embedded Device Requirement
HDR	Host Device Requirement
NDR	Network Device Requirement

Those are only applicable to their domain. For a component deployed in railway systems, all those groups might be relevant.

Requirement enhancements

Each of the requirements defined in section 4-2 (CR, SAR, EDR, HDR and NDR) might define additions (enhancements). Which of these enhancements must be implemented depends on the chosen security level. The mapping is also defined by the corresponding requirement.

SECURE DEVELOPMENT LIFECYCLE: IEC 62443-4-1

In addition to requirements for the finished product, IEC 62443 also contains practices for a secure development lifecycle as part of a defense in depth approach. This is fully laid out in part 4-1 of the series. The development lifecycle is defined to include security requirements definition, secure design, secure implementation, coding guidelines, verification and validation, defect management, patch (update) management and product end-of-life. Therefore, a developer must not only develop a product according to the requirements but also operate in compliance with them in general. This may require major restructuring and changes to any previously defined procedures. These requirements are applied only to the developer and maintainer of a product, but not the user or integrator.

Like the security levels used above, 4-1 defines Maturity Levels, which describe the level of compliance with the standard by a supplier.

Instead of FRs, practices are defined, each of which containing its own requirements, comparable to the relation between FRs and CRs above.

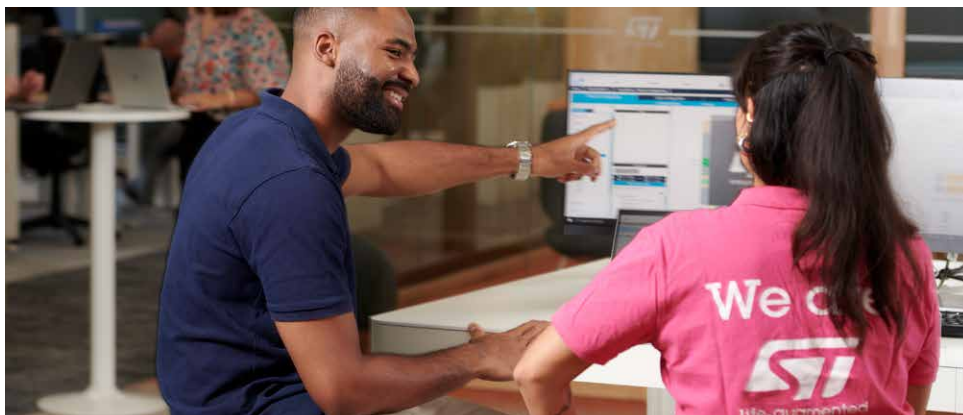
Level	Name	Description
1	Initial	Undocumented, unrepeatable and inconsistent processes
2	Managed	Written policies, proof of training and compliance, lack of experience
3	Practiced	Repeatable performance, practiced processes, proof of experience
4/5	Improving	Monitoring performance and compliance, steady improvement

Two particularly relevant requirements regarding the choice of a hardware platform for a component/product are SM-6 and SM-7 of practice 1 (Security Management).

SM-6 (file integrity) states the requirement, that there must be “an integrity verification mechanism for all scripts, executables and other important files included in the project”. The rationale behind this is that a user must be able to verify that the software provided by the supplier has not been altered. As it may not be possible to read out software from a device for security reasons, one approach to fulfilling this requirement are secure boot mechanisms, which perform integrity checks every time a device starts up.

In addition to that, SM-7 (development environment security) requires that “procedural and technical controls shall be employed for protecting the product during development, production and delivery”. This directive aims to prevent breach of integrity and manipulation of the product, including its software, during the development process. While one aspect of this is ensuring a secure development environment and the protection of signing keys, this may also include making sure that parties involved in certain development steps only have access to information they require. An example of this may be different software stages in embedded devices: The party developing the application may not need access to firmware performing security relevant functionality underlying security function would be Isolation.

#	Pref.	Name
1	SM	Security management
2	SR	Specification of security requirements
3	SD	Secure by design
4	SI	Secure implementation
5	SV	Security verification and validation testing
6	DM	Management of security-related issues
7	SUM	Security update management
8	SG	Security guidelines



SECURITY LEVELS

One core concept present throughout IEC 62433 is the definition of security levels. The chosen security level decides which security requirements and which of their enhancements need to be implemented. Four relevant security levels are defined: SL1 aims at preventing accidental exposure of information, without considering a party actively trying to

gain access to said information. SL 2 through 4 consider increasingly more motivated and well-equipped entities actively trying to access it while employing more and more IACS specific skills. The appropriate security level should be chosen based on a threat assessment specific to the present scenario in which a system or component is expected to operate.

List of security levels

Level	Skills	Motivation	Resources
SL1	None	None	None
SL2	Generic	Low	Low
SL3	IACS specific	Moderate	Moderate
SL4	IACS specific	High	Extended

PROTECTING SAFETY-CRITICAL SYSTEMS

A safety-critical train-control system, such as a train control or signaling system component, requires the strongest possible protection to prevent interference that could cause accidents leading to injury or death. These will be assigned a high security level, which could be up to SL4 in the most exposed cases. In such systems, in addition to software, cybersecurity is built into the architecture by separating safety critical systems from non-critical systems and ensuring only very limited communication between them. Also, physical access to all systems must be restricted.

NON-SAFETY-CRITICAL SYSTEMS

Systems such as passenger counters or travel information displays, may be assigned a lower safety level, such as SL1 or SL2. Threats can include deliberate attacks aiming to cause malfunctions. On the other hand, well-meaning actors such as subsystem suppliers can cause unintended errors. Either may lead to economic damage such as penalties. Preventing incorrect updates to devices, for example, can protect against attackers or subsystem suppliers who may brick the systems without intention.

Effective defenses include robust authentication and authorization, encryption (TLS), security logging, and decryption and verification of deployments such as Debian packages. Blocking non-essential interfaces, for example by deactivating unused USB ports and using a firewall, is also important.

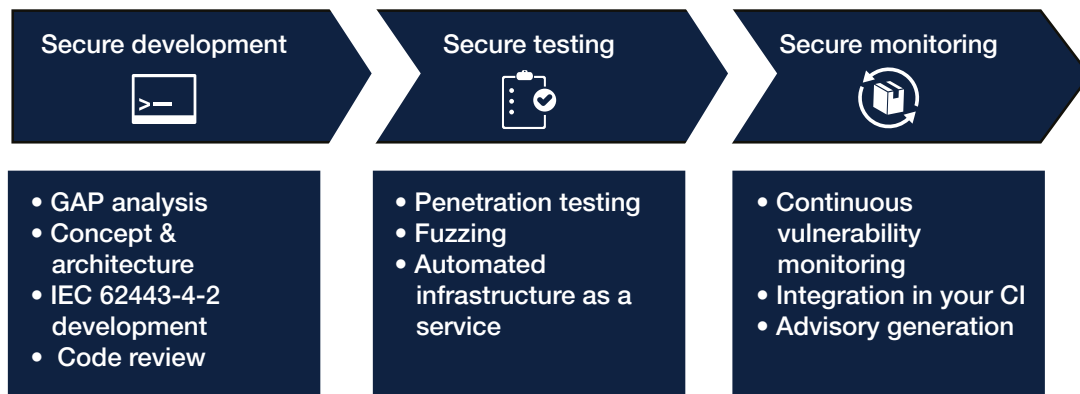


DEVELOPMENT, TESTING AND MONITORING SERVICES FOR CRA-COMPLIANT APPLICATIONS

codewerk

Specialized services from a trusted technical partner can help facilitate development of properly protected applications; in particular, help to ensure CRA compliance including testing and certification.

As an ST Authorized Partner, Codewerk provides services that cover the security lifecycle, including secure development, testing, and monitoring.



Secure development

- **Gap analysis:** evaluation of current security measures in the development process and customer application to identify gaps compared to the industry standards IEC 62443-4-1 (process) and IEC 62443-4-2 (component). This is the basis for creating a development concept and architecture. Gap analysis helps assess the time and cost needed for concept and implementation.
- **Concept & architecture:** creation of security concepts and architectures for embedded systems that take threat models and security mechanisms into account. This provides the basis for implementation.
- **IEC 62443-4-2 development:** implementation of the security requirements for industrial components in accordance with IEC 62443-4-2. This includes integrating security functions such as authentication and cryptography into the application.
- **Code review:** systematic review of the source code for security gaps, vulnerabilities, CWE, and violations of secure coding guidelines. The aim is to minimize security risks from the earliest possible stage of the development process.

Secure testing

- **Penetration testing:** simulation of targeted attacks on hardware and firmware to identify vulnerabilities and potential exploit possibilities. This includes black-box, white-box, and gray-box testing.
- **Fuzzing:** this is an automated test procedure in which random or unexpected inputs are generated to provoke errors or security vulnerabilities. This is particularly relevant for interfaces and proprietary communication protocols and can be done on the basis of black-box, white-box, or gray-box. Also, source-code based fuzzing is possible.
- **Automated infrastructure as a service:** use of automated test and build pipelines for continuous security checks. This enables early and recurring validation of security requirements.

Secure monitoring

- **Continuous vulnerability monitoring:** ongoing monitoring of the software components to guard against new vulnerabilities by continuous checking of known-vulnerability databases and security feeds, to be able to react promptly to threats.
- **Continuous integration:** incorporating automated security scans and tests into the CI/CD pipeline to seamlessly integrate security checks into the development and release process.
- **Advisory generation:** creation and publication of security advisories and updates for discovered vulnerabilities to proactively inform customers and partners about security risks and corresponding countermeasures.

Book your cost-free-strategy meeting here at Codewerk.
We will contact you in less than 24h.

Codewerk GmbH

Siemensallee 75
76187 Karlsruhe
+ 49 721 9841 4678

sales@codewerk.de
www.codewerk.de



CYBERSECURITY HARDWARE EXPERTISE

As IEC 62443 becomes aligned with the CRA, this will provide an effective underlying platform for producing railway systems that meet the Act's stringent cybersecurity requirements, expertise is also required at the semiconductor level. To ensure new IoT devices can meet the CRA (and RED) requirements, the underlying microcontroller must be demonstrably secure and offer capabilities including:

- Device attestation to ensure devices can be commissioned securely
- Update capability that enables devices to be remotely patched if vulnerabilities are identified
- Secure storage for cryptographic keys, customer credentials, and other information
- Resilience against physical attacks (for microcontrollers claiming tamper resistance)

Many IoT device makers do not have access to such extensive security knowledge in-house, so choosing a microcontroller (MCU) known to meet industry standards such as Security Evaluation Standard for IoT Platforms (SESIP) is an effective starting point. The MCU vendor takes responsibility for building and maintaining the required low-level security functionality, as well as independently validating the microcontroller security. This saves device makers the investment needed to establish this expertise and allows them to devote more resources towards enhancing the core product functionality.

SESIP: INDUSTRY STANDARD FOR HARDWARE SECURITY EVALUATION

SESIP is a vendor-agnostic, multilevel security certification standard for devices being deployed in the IoT. Since being published as a European standard (EN 17927) in November 2023, the methodology is recognized within the European market.

There are five levels of SESIP certification. The higher the level, the more secure the device. SESIP Level 1, which is self-assessed, is the baseline requirement for most IoT device-level programs. SESIP Level 2 involves black-box penetration testing and provides moderate security assurance. However, to meet the incoming CRA and RED requirements, the recommended best practice is to aim for Level 3.

Achieving SESIP Level 3 involves an independent white-box vulnerability analysis, which consists in a thorough assessment of the robustness by the evaluation lab that will look for attack paths while having full access to the detailed baseline architecture of the hardware and to the source code and binary of the root of trust firmware. Inherited from the well-known Common Criteria methodology used in the IT industry to assess the security of IT products, this type of impartial validation is important in providing confidence that the security claims being made by the microcontroller manufacturer are both true and robust.

STM32 ECOSYSTEM AND SECURITY FEATURES

ST provides pre-certified STM32 MCUs including ultra-low-power **STM32U5** and **STM32U0**, high-performance **STM32H5** and **STM32H7R/S**, and wireless **STM32WBA** series, as well as **STM32MP** microprocessors (MPUs). These devices, including the Root of Trust (RoT), now target SESIP Level 3 certifications with both software resistance and protection against physical attacks.

In addition to the **STM32 Open Development Environment**, ST provides tools and resources to help device makers ensure compliance with the regulatory requirements. These include reference designs, software libraries, and development kits to help build IoT devices that meet the regulatory requirements. This includes providing tools for robust management of low-level security capabilities such as over-the-air updates.

Building on this, ST's **STM32Trust solution** provides a robust, multilevel strategy for developers to enhance security

and comply with the different regulations mandated by the latest certification schemes.

As a security framework, STM32Trust offers a complete toolset for code and execution protection and ensures IP protection, firmware authenticity and secure firmware updates, as well as secure data and the use of validated credentials. STM32Trust helps protect assets by identifying and analyzing threats and vulnerabilities to define protections and countermeasures and mitigating them with ready-to-use security functions and services.

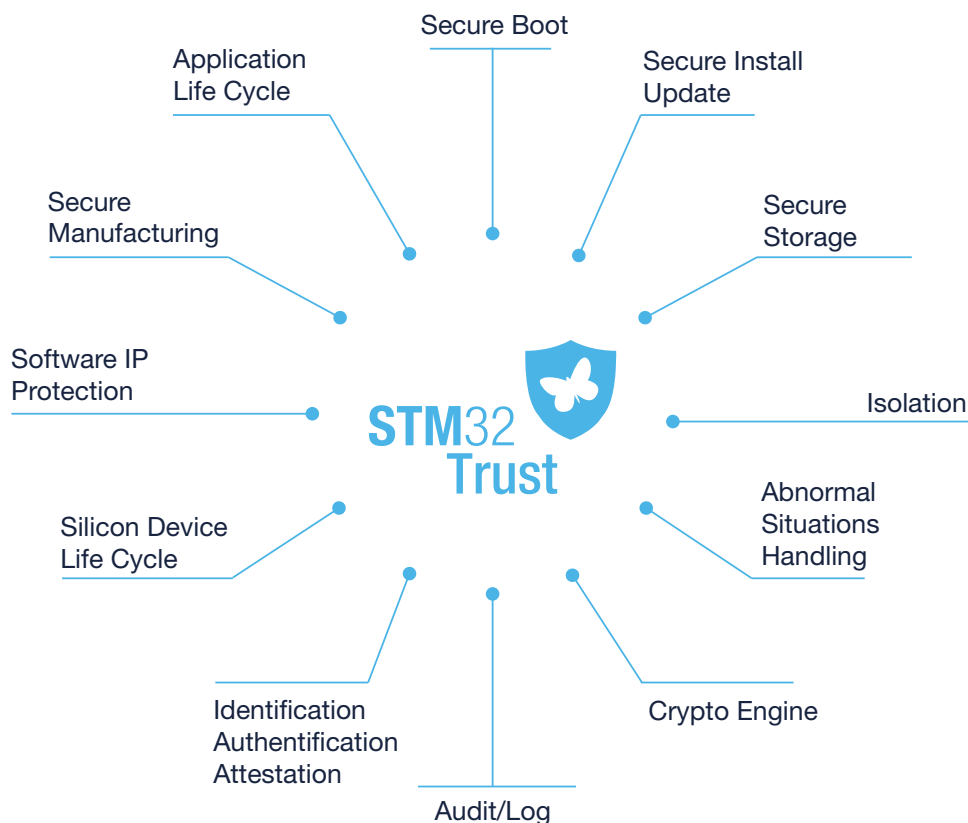
STM32Trust is based on the SESIP and PSA Certified (Platform Security Architecture) by Arm® product certification schemes.

ST's security solutions and services help IoT device makers comply with the regulatory requirements for wireless devices, including IEC 62443, and bring their products to market quickly and efficiently.

STM32TRUST SECURITY FRAMEWORK

STM32Trust ensures stronger, more scalable security for embedded systems.

The framework includes security functions in hardware and software (see figure below), as well as design services, from ST and third parties. STM32Trust complies with the latest national regulations and security standards for applications.



STM32Trust comprises functions to ease cybersecurity compliance for embedded systems.

STM32TRUST IN FOCUS

The 12 functions that comprise STM32Trust are described here:

- 1. Secure boot:** Ability to ensure the authenticity and integrity of an application that runs inside a device.
- 2. Secure install/update:** Installation or update of firmware with initial checks of integrity and authenticity before programming.
- 3. Silicon device lifecycle:** Control states to securely protect silicon-device assets through a constrained path.
- 4. Isolation:** Isolation between trusted and non-trusted parts of an application.
- 5. Secure storage:** Ability to securely store secrets like data or keys (and to access them without them being visible externally).
- 6. Crypto engine:** Ability to process cryptographic algorithms, as recommended by a security assurance level.

7. Secure manufacturing: Initial device provisioning in an unsecured environment with overproduction control. Potential secured personalization.

8. Identification / authentication / attestation: Unique identification of a device and/or software package, and ability to detect its authenticity, from inside the device or externally.

9. Software IP protection: Ability to protect a section or the whole software package against external or internal reading. Can be multi-tenant.

10. Abnormal situation handling: Ability to detect abnormal situations (both hardware and software) and to take adapted decisions like the removal of secret data.

11. Audit/Log: Keep track of security events in an unchangeable way.

12. Application lifecycle: Define unchangeable incremental states to securely protect application states and assets.

SECURE APPLICATIONS ON SESIP-CERTIFIED MICROCONTROLLERS

Selecting a microcontroller and RoT that are certified to SESIP Level 3 simplifies and accelerates achieving the full SESIP Level 3 certification required for the end product.

This is because of the concept of reuse, or composition, in SESIP. Building an IoT device around a SESIP Level 3 certified microcontroller and RoT can help minimize or even avoid any further validation of the component when going through full-device certification. This relieves much of the complexity surrounding RED and CRA compliance and can significantly speed up the end-to-end process. Working with a SESIP-certified STM32 MCU and RTOS, and assisted with Codewerk's cybersecurity know-how, developers can establish certifiable protection for safety-critical systems such as braking controllers.

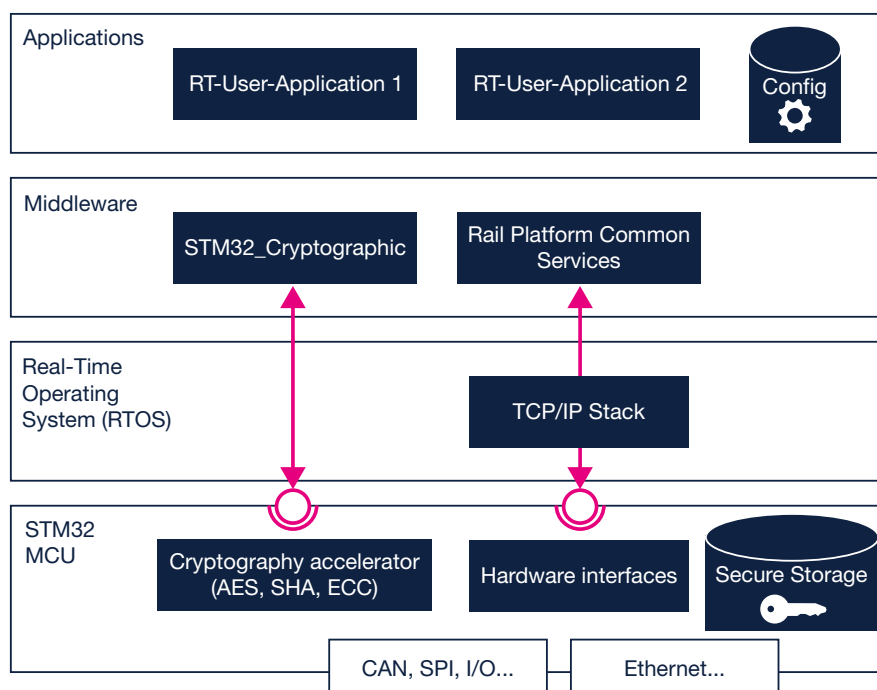


Figure 1: Safety-critical system architecture developed for SESIP Level 3 certified microcontroller

On the other hand, a suitable architecture for non-safety-critical development, such as a passenger information system, would typically be hosted on a more powerful STM32 MPU running X-Linux-RT/QT.

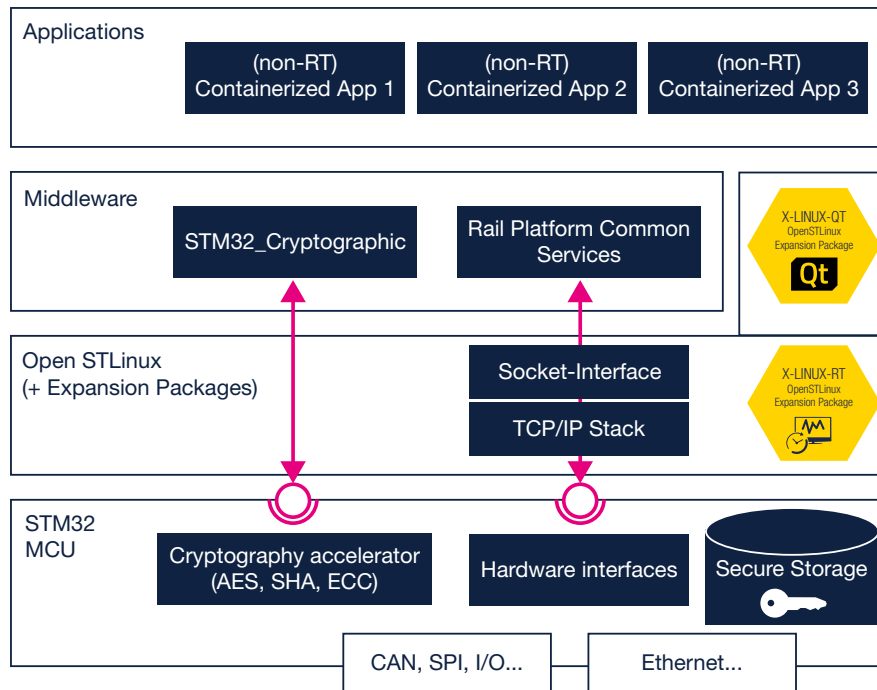


Figure 2: STM32 MPU and Linux services for non-safety-critical application such as a passenger information system.

CONCLUSION

National railway networks are considered critical infrastructure and hence require system developers to apply a rigorous approach to ensure cybersecurity. As regulation such as the EU Cyber Resilience Act (CRA) continues to evolve, developers currently developing new railway components need three important elements in their projects:

- Development framework based on IEC 62443 standards series
- SESIP Level 3 microcontrollers and microprocessors with STM32Trust hardware security framework
- Codewerk's portfolio of secure development and security testing services

With these resources available, development can be simplified, focused, and meet state-of-the-art specifications and best practices for cybersecurity.

ADDITIONAL RESOURCES

Cyber Resilience Act Requirements Standards Mapping - Joint Research Centre & ENISA Joint Analysis [\[ENISA\]](#)

Cyber Resilience Act Requirements Standards Mapping [\[JRC Publications Repository\]](#)

STM32Trust security framework [\[ST ecosystem page\]](#)

Building trust: the journey towards security with standardized open-source STM32 MPU solutions [\[ST Whitepaper\]](#)

Cyber security for component manufacturers: secure by any standards [\[Codewerk portfolio page\]](#)

APPENDIX: SECURITY FUNCTION MAPPING

Mapping of CRs and REs to FR SL levels 1-4

SRs and REs	SL1	SL2	SL3	SL4
FR 1 - Identification and authentication control (IAC)				
CR 1.1 - Human user identification and authentication	√	√	√	√
RE(1) Unique identification and authentication		√	√	√
RE(2) Multifactor authentication for all interfaces			√	√
CR 1.2 - Software process and device identification and authentication		√	√	√
RE(1) Unique identification and authentication			√	√
CR 1.3 - Account management	√	√	√	√
CR 1.4 - Identifier management	√	√	√	√
CR 1.5 - Authenticator management	√	√	√	√
RE(1) Hardware security for authenticators			√	√

STM32Trust security functions mapping on IEC 62443-4-2

STM32Trust secure storage

Req.	Desc.
CR 1.5 RE (1) – SL-C3	Authenticator management Hardware security for authenticators
EDR 3.2	Protection from malicious code
CR 3.4 RE (1) – SL-C2 RE (2) – SL-C3	Software and information integrity Authenticity of software and information Automated notification of integrity violations
CR 3.9 RE (1) – SL-C4	Protection of audit information Audit record on write-once media
CR 4.1	Information confidentiality
CR 4.2 RE (1) – SL-C3 RE (2) – SL-C3	Information persistence Erase of shared memory resources Erase verification
CR 7.1 RE (1) – SL-C2	Denial of service protection Manage communication load from component
CR 7.2	Resource management

IEC 62443-4-2 requirements

STM32Trust secure boot, secure install, and secure update

Req.	Desc.
EDR 3.2	Protection from malicious code
CR 3.4 RE (1) – SL-C2 RE (2) – SL-C3	Software and information integrity Authenticity of software and information Automated notification of integrity violations
CR 3.5	Input validation
EDR 3.14 RE (1)	Integrity of the boot process Authenticity of the boot process
CR 7.1 RE (1) – SL-C2	Denial of service protection Manage communication load from component
CR 7.3 RE (1) – SL-C2	Control system backup Backup integrity verification
CR 7.4	Control system recovery and reconstitution

IEC 62443-4-2 requirements

At STMicroelectronics
we create
technology that
starts with You



Order code: **WP2506CYBRAIL**

For more information on ST products and solutions, visit www.st.com

© STMicroelectronics - August 2025 - Printed in the United Kingdom - All rights reserved
ST and the ST logo are registered and/or unregistered trademarks of STMicroelectronics International NV or its affiliates in the EU and/or elsewhere. In particular, ST and the ST logo are registered in the US patent and trademark office. For additional information about ST trademarks, please refer to www.st.com/trademarks.
All other product or service names are the property of their respective owners.

